

Ecco la checklist completa e consecutiva per la tua webapp basata sulla norma **ISO/IEC 27001:2022**.

La lista comprende le **86 domande** relative ai requisiti del sistema di gestione (Clausole 4-10) seguite dai **93 controlli** dell'Appendice A, per un totale di **179 punti di controllo**.

PARTE 1: Requisiti del Sistema di Gestione (ISO/IEC 27001:2022)

4. Context of the Organization

1. (4.1) Sono stati determinati i fattori esterni rilevanti per la sicurezza delle informazioni?
2. (4.1) Sono stati identificati i fattori interni rilevanti che influenzano l'ISMS?
3. (4.1) Viene effettuato il monitoraggio e il riesame periodico di tali fattori esterni e interni?
4. (4.2) È stato redatto un elenco delle parti interessate rilevanti per l'ISMS?
5. (4.2) Sono stati mappati i requisiti specifici di tali parti interessate (es. legali, contrattuali)?
6. (4.2) È stato deciso quali di questi requisiti saranno affrontati attraverso l'ISMS?
7. (4.3) Il campo di applicazione (Scope) dell'ISMS è disponibile come informazione documentata?
8. (4.3) Lo scope definisce chiaramente i confini fisici, logici e organizzativi del sistema?
9. (4.3) Lo scope tiene conto delle interfacce e dipendenze con attività svolte da altre organizzazioni?
10. (4.4) L'organizzazione ha stabilito, attuato e migliorato i processi necessari e le loro interazioni?

5. Leadership

11. (5.1) L'alta direzione assicura che la politica e gli obiettivi siano compatibili con la direzione strategica?
12. (5.1) I requisiti di sicurezza sono integrati nei processi operativi dell'organizzazione?
13. (5.1) Viene garantita la disponibilità delle risorse necessarie per l'ISMS?

- 14. (5.1) La direzione comunica l'importanza di una gestione efficace della sicurezza?
- 15. (5.1) L'alta direzione assicura che l'ISMS raggiunga i risultati attesi?
- 16. (5.1) La direzione guida e supporta le persone affinché contribuiscano all'efficacia del sistema?
- 17. (5.1) Viene promosso attivamente il miglioramento continuo?
- 18. (5.1) Viene fornito supporto agli altri ruoli gestionali per dimostrare la leadership nelle loro aree?
- 19. (5.2) La politica della sicurezza è appropriata alle finalità dell'organizzazione?
- 20. (5.2) La politica fornisce il quadro di riferimento per fissare gli obiettivi di sicurezza?
- 21. (5.2) La politica include un impegno a soddisfare i requisiti applicabili?
- 22. (5.2) La politica include un impegno al miglioramento continuo dell'ISMS?
- 23. (5.2) La politica è disponibile come informazione documentata ed è comunicata internamente?
- 24. (5.2) La politica è disponibile alle parti interessate, se appropriato?
- 25. (5.3) Le responsabilità e le autorità per i ruoli rilevanti sono assegnate e comunicate?
- 26. (5.3) È assegnata l'autorità per assicurare che l'ISMS sia conforme ai requisiti della norma?
- 27. (5.3) È assegnata la responsabilità di riferire alla direzione sulle prestazioni dell'ISMS?

6. Planning

- 28. (6.1.1) Sono stati determinati i rischi e le opportunità per assicurare i risultati attesi?
- 29. (6.1.1) Sono pianificate azioni per prevenire o ridurre gli effetti indesiderati?
- 30. (6.1.1) Le azioni per affrontare rischi e opportunità sono integrate nei processi ISMS?
- 31. (6.1.1) Viene valutata l'efficacia delle azioni intraprese?

32. (6.1.2) Sono stabiliti e mantenuti i criteri di accettazione del rischio?
33. (6.1.2) Il processo di risk assessment produce risultati consistenti, validi e comparabili?
34. (6.1.2) Vengono identificati i rischi legati alla perdita di riservatezza, integrità e disponibilità?
35. (6.1.2) Per ogni rischio identificato è stato nominato un proprietario del rischio (Risk Owner)?
36. (6.1.2) Vengono valutate le conseguenze potenziali della materializzazione dei rischi?
37. (6.1.2) Viene valutata la probabilità realistica di accadimento dei rischi?
38. (6.1.2) Vengono determinati i livelli di rischio in base all'analisi?
39. (6.1.2) I rischi analizzati vengono prioritizzati per il trattamento del rischio?
40. (6.1.2) L'organizzazione conserva informazione documentata sul processo di risk assessment?
41. (6.1.3) Sono selezionate opzioni appropriate per il trattamento del rischio?
42. (6.1.3) Sono determinati tutti i controlli necessari per attuare le opzioni scelte?
43. (6.1.3) I controlli scelti sono confrontati con l'Appendice A per verificare omissioni?
44. (6.1.3) È stata prodotta una Dichiarazione di Applicabilità (SoA) completa?
45. (6.1.3) La SoA include le giustificazioni per i controlli inclusi ed esclusi?
46. (6.1.3) È stato formulato un piano di trattamento del rischio (Risk Treatment Plan)?
47. (6.1.3) I Risk Owners hanno approvato il piano di trattamento e accettato i rischi residui?
48. (6.1.3) Viene conservata informazione documentata sul processo di risk treatment?
49. (6.2) Gli obiettivi di sicurezza sono stabiliti per le funzioni e i livelli pertinenti?
50. (6.2) Gli obiettivi sono consistenti con la politica della sicurezza?

- 51. (6.2) Gli obiettivi tengono conto dei requisiti di sicurezza e dei risultati dei rischi?
- 52. (6.2) Gli obiettivi sono misurabili (se praticabile) e monitorati?
- 53. (6.2) Gli obiettivi sono comunicati e aggiornati come appropriato?
- 54. (6.2) Viene conservata informazione documentata sugli obiettivi di sicurezza?
- 55. (6.2) La pianificazione degli obiettivi definisce cosa, risorse, chi, quando e valutazione?
- 56. (6.3) Le modifiche all'ISMS sono effettuate in modo pianificato?

7. Support

- 57. (7.1) L'organizzazione fornisce le risorse necessarie per il mantenimento dell'ISMS?
- 58. (7.2) È stata determinata la competenza necessaria per le persone che influenzano la sicurezza?
- 59. (7.2) Viene assicurata la competenza tramite istruzione, formazione o esperienza?
- 60. (7.2) Vengono intraprese azioni per acquisire competenze e ne viene valutata l'efficacia?
- 61. (7.2) Viene conservata informazione documentata come evidenza della competenza?
- 62. (7.3) Il personale è consapevole della politica di sicurezza delle informazioni?
- 63. (7.3) Le persone sono consapevoli del loro contributo all'efficacia dell'ISMS?
- 64. (7.3) Il personale comprende le implicazioni del non essere conformi ai requisiti ISMS?
- 65. (7.4) Sono definite le necessità di comunicazione interna ed esterna (cosa, quando, chi, come)?
- 66. (7.5.1) Il sistema include tutta la documentazione richiesta dalla norma ISO 27001?
- 67. (7.5.2) I documenti hanno identificazione (titolo, data, autore) e formato appropriati?
- 68. (7.5.2) Esiste un processo di revisione e approvazione per idoneità e adeguatezza?
- 69. (7.5.3) Le informazioni documentate sono disponibili e idonee all'uso dove e quando servono?

70. (7.5.3) I documenti sono protetti da perdita di riservatezza, uso improprio o integrità?

71. (7.5.3) Vengono gestite distribuzione, accesso, recupero, conservazione e controllo modifiche?

72. (7.5.3) I documenti di origine esterna necessari sono identificati e controllati?

8. Operation

73. (8.1) Sono stabiliti criteri per i processi necessari all'ISMS?

74. (8.1) I processi sono controllati in accordo con i criteri stabiliti?

75. (8.1) Viene conservata informazione documentata per avere fiducia che i processi siano pianificati?

76. (8.1) L'organizzazione controlla le modifiche pianificate e revisiona quelle involontarie?

77. (8.1) I processi, prodotti o servizi forniti dall'esterno rilevanti per l'ISMS sono controllati?

78. (8.2) Vengono eseguiti risk assessment a intervalli pianificati o in caso di cambiamenti?

79. (8.2) Viene conservata informazione documentata sui risultati dei risk assessment?

80. (8.3) L'organizzazione implementa effettivamente l'Information Security Risk Treatment Plan?

81. (8.3) Viene conservata informazione documentata sui risultati del risk treatment?

9. Performance Evaluation

82. (9.1) Viene determinato cosa monitorare, inclusi i processi e i controlli di sicurezza?

83. (9.1) Vengono analizzate le prestazioni e l'efficacia dell'ISMS?

84. (9.2) Gli audit interni sono condotti a intervalli pianificati?

85. (9.3) L'alta direzione riesamina l'ISMS per assicurarne continua idoneità e adeguatezza?

10. Improvement

86. (10.2) In caso di non conformità, l'organizzazione intraprende azioni per controllarla e correggerla?

PARTE 2: Controlli dell'Appendice A (ISO/IEC 27001:2022)

A.5 Organizational Controls

- 87. (5.1) Sono definite e revisionate le politiche per la sicurezza delle informazioni?
- 88. (5.2) I ruoli e le responsabilità per la sicurezza sono definiti e allocati?
- 89. (5.3) Le mansioni e le aree di responsabilità conflittuali sono segregate?
- 90. (5.4) La direzione richiede al personale di applicare la sicurezza secondo le politiche?
- 91. (5.5) Vengono mantenuti contatti appropriati con le autorità competenti?
- 92. (5.6) Vengono mantenuti contatti con gruppi di interesse speciale o forum di sicurezza?
- 93. (5.7) Vengono raccolte e analizzate informazioni sulle minacce (threat intelligence)?
- 94. (5.8) La sicurezza delle informazioni è integrata nella gestione dei progetti?
- 95. (5.9) Viene mantenuto un inventario delle informazioni e degli asset associati?
- 96. (5.10) Sono definite regole per l'uso accettabile delle informazioni e degli asset?
- 97. (5.11) Gli asset vengono restituiti dal personale al termine del rapporto di lavoro?
- 98. (5.12) Le informazioni sono classificate in base alle necessità dell'organizzazione?
- 99. (5.13) Sono implementate procedure per l'etichettatura delle informazioni (labelling)?
- 100. (5.14) Sono attive regole o accordi per il trasferimento sicuro delle informazioni?
- 101. (5.15) L'accesso logico e fisico è controllato in base ai requisiti di business?
- 102. (5.16) Viene gestito l'intero ciclo di vita delle identità digitali?
- 103. (5.17) L'allocazione delle info di autenticazione è gestita tramite un processo formale?

104. (5.18) I diritti di accesso sono forniti, revisionati e modificati secondo le regole?
105. (5.19) Vengono gestiti i rischi di sicurezza nelle relazioni con i fornitori?
106. (5.20) I requisiti di sicurezza sono concordati negli accordi con i fornitori?
107. (5.21) Viene gestita la sicurezza nella catena di fornitura ICT?
108. (5.22) Le pratiche di sicurezza dei fornitori sono regolarmente monitorate?
109. (5.23) Sono definiti processi per l'acquisizione e l'uso sicuro dei servizi cloud?
110. (5.24) È pianificata la gestione degli incidenti di sicurezza delle informazioni?
111. (5.25) Gli eventi di sicurezza sono valutati per decidere se categorizzarli come incidenti?
112. (5.26) Gli incidenti di sicurezza sono gestiti secondo procedure documentate?
113. (5.27) La conoscenza acquisita dagli incidenti è usata per migliorare i controlli?
114. (5.28) Sono stabilite procedure per l'identificazione e raccolta di prove (evidence)?
115. (5.29) La sicurezza delle informazioni è mantenuta durante le interruzioni (disruption)?
116. (5.30) La prontezza ICT per la continuità operativa è pianificata e testata?
117. (5.31) I requisiti legali, regolatori e contrattuali sono identificati e aggiornati?
118. (5.32) Sono implementate procedure per proteggere i diritti di proprietà intellettuale?
119. (5.33) I record sono protetti da perdita, distruzione o falsificazione?
120. (5.34) Vengono rispettati i requisiti per la privacy e protezione dei dati (PII)?
121. (5.35) L'approccio ISMS è sottoposto a revisione indipendente periodicamente?
122. (5.36) La conformità alle politiche e agli standard di sicurezza è revisionata?
123. (5.37) Le procedure operative per i sistemi di elaborazione sono documentate?

A.6 People Controls

- 124. (6.1) Vengono eseguiti controlli (screening) sui candidati prima dell'assunzione?
- 125. (6.2) I contratti di lavoro dichiarano le responsabilità per la sicurezza?
- 126. (6.3) Il personale riceve regolarmente formazione sulla consapevolezza della sicurezza?
- 127. (6.4) È formalizzato un processo disciplinare per violazioni della sicurezza?
- 128. (6.5) Le responsabilità di sicurezza rimangono valide dopo la cessazione del rapporto?
- 129. (6.6) Vengono firmati accordi di riservatezza (NDA) appropriati?
- 130. (6.7) Sono implementate misure di sicurezza per il lavoro remoto?
- 131. (6.8) Esiste un meccanismo per segnalare tempestivamente eventi di sicurezza?

A.7 Physical Controls

- 132. (7.1) Sono definiti perimetri di sicurezza fisica per proteggere aree sensibili?
- 133. (7.2) Le aree sicure sono protette da controlli di accesso fisico appropriati?
- 134. (7.3) La sicurezza fisica per uffici, stanze e strutture è progettata e attuata?
- 135. (7.4) I locali sono monitorati continuamente per accessi fisici non autorizzati?
- 136. (7.5) È implementata la protezione contro minacce fisiche e ambientali?
- 137. (7.6) Sono definite misure di sicurezza per il lavoro all'interno di aree sicure?
- 138. (7.7) Vengono applicate regole di "clear desk" e "clear screen"?
- 139. (7.8) Le apparecchiature sono posizionate in modo sicuro e protette?
- 140. (7.9) Gli asset situati fuori sede (off-premises) sono protetti?
- 141. (7.10) I supporti di memoria (storage media) sono gestiti durante tutto il ciclo di vita?
- 142. (7.11) Le strutture sono protette da interruzioni dei servizi di supporto (energia)?

- 143. (7.12) I cavi di alimentazione e dati sono protetti da intercettazioni o danni?
- 144. (7.13) Le apparecchiature sono mantenute correttamente per garantirne la disponibilità?
- 145. (7.14) I dati sensibili vengono rimossi prima dello smaltimento delle apparecchiature?

A.8 Technological Controls

- 146. (8.1) Le informazioni sui dispositivi end-point degli utenti sono protette?
- 147. (8.2) L'allocazione e l'uso dei diritti di accesso privilegiato sono limitati?
- 148. (8.3) L'accesso alle informazioni è ristretto secondo la politica di controllo accessi?
- 149. (8.4) L'accesso al codice sorgente e alle librerie software è gestito correttamente?
- 150. (8.5) Sono implementate tecnologie di autenticazione sicura?
- 151. (8.6) L'uso delle risorse è monitorato e regolato in base alla capacità?
- 152. (8.7) È implementata la protezione contro il malware (antivirus/EDR)?
- 153. (8.8) Le vulnerabilità tecniche sono identificate e gestite prontamente?
- 154. (8.9) Le configurazioni di sicurezza (hardening) sono stabilite e monitorate?
- 155. (8.10) Le informazioni vengono eliminate quando non sono più necessarie?
- 156. (8.11) Il mascheramento dei dati (data masking) è utilizzato secondo le necessità?
- 157. (8.12) Sono applicate misure di prevenzione della fuga di dati (DLP)?
- 158. (8.13) Vengono eseguiti backup regolari e testati delle informazioni?
- 159. (8.14) È implementata la ridondanza per soddisfare i requisiti di disponibilità?
- 160. (8.15) Vengono prodotti, protetti e analizzati log delle attività ed eventi?
- 161. (8.16) Le reti e i sistemi sono monitorati per comportamenti anomali?
- 162. (8.17) Gli orologi dei sistemi sono sincronizzati con sorgenti temporali approvate?

- 163. (8.18) L'uso di programmi utility privilegiati è strettamente controllato?
- 164. (8.19) L'installazione di software sui sistemi operativi è gestita in modo sicuro?
- 165. (8.20) Le reti e i dispositivi di rete sono protetti e gestiti in sicurezza?
- 166. (8.21) I requisiti di sicurezza dei servizi di rete sono monitorati?
- 167. (8.22) Gruppi di servizi, utenti e sistemi sono segregati nelle reti?
- 168. (8.23) L'accesso ai siti web esterni è gestito (web filtering)?
- 169. (8.24) Sono definite regole per l'uso efficace della crittografia?
- 170. (8.25) Sono stabilite e applicate regole per lo sviluppo sicuro del software?
- 171. (8.26) I requisiti di sicurezza sono specificati per lo sviluppo di applicazioni?
- 172. (8.27) Sono stabiliti e applicati principi di ingegneria per sistemi sicuri?
- 173. (8.28) Vengono applicati principi di codifica sicura (secure coding)?
- 174. (8.29) I test di sicurezza sono integrati nel ciclo di vita dello sviluppo?
- 175. (8.30) Lo sviluppo affidato all'esterno (outsourced) è monitorato e revisionato?
- 176. (8.31) Gli ambienti di sviluppo, test e produzione sono separati e sicuri?
- 177. (8.32) I cambiamenti ai sistemi sono soggetti a procedure di change management?
- 178. (8.33) Le informazioni di test sono selezionate e protette adeguatamente?
- 179. (8.34) I test di audit sui sistemi operativi sono pianificati e concordati?